

PHISHING DETECTION SYSTEM

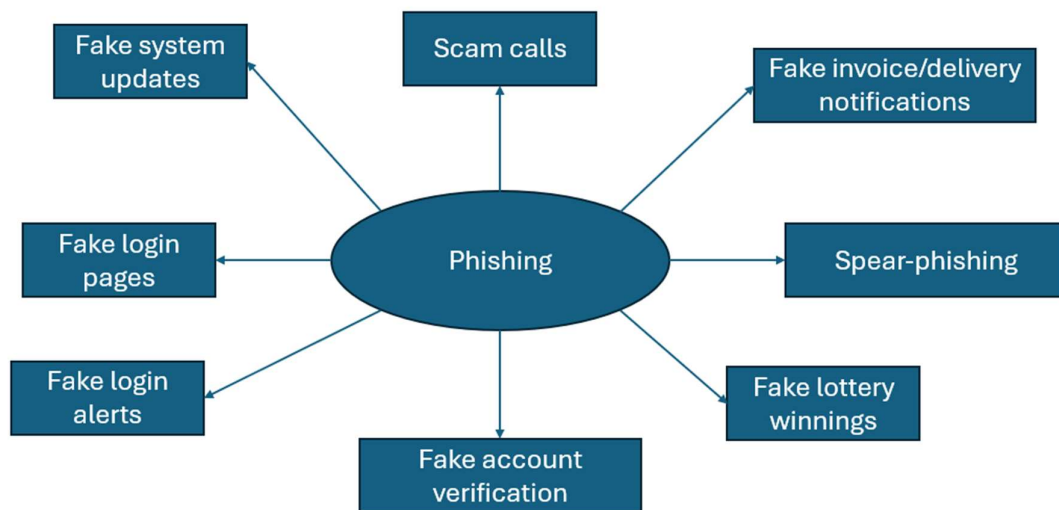
Contents

Introduction	2
Main phishing detection system	3
Technical controls against phishing	4

Introduction

This phishing detection system is designed to aid users in detecting and preventing successful phishing attempts. This system is built on technical, behavioural and human layers. This phishing detection system was developed as phishing is one of the biggest attack vectors used by all current threat actors in Cybersecurity. For those who may not what phishing is, phishing is the act of tricking someone into giving information or downloading something without realising it. phishing is effective because it targets the user instead of the technical controls. This is a common vector for attackers because humans can be stressed, panicked, scared and tricked easily sometimes. Some common types of phishing currently used as fake system updates, fake login pages and fake login alerts.

While this system cannot completely prevent phishing, it can reduce the chance of success heavily. This system may not be as effective in detecting or preventing spear-phishing. This is because spear-phishing uses personalised details to trick a specific target into providing credentials or downloading malware. However, this system may be effective against most other types of phishing due its behavioural analysis of phishing, technical controls used to catch human error and the human layer making the final decision with my security architecture's decision framework. This system should not be blindly trusted as the only way to reduce the chances of phishing. Make sure to adapt this system based on your own security needs and threat model.



The spider diagram shows the common phishing tactics used by attackers in 2026. While spear-phishing is usually used by threat actors such as organised cybercriminals or nation-state/APT, it is important to be aware of as an attacker may be able to use a spear-phishing attack if they were to gain enough information about their target.

Main phishing detection system

In this section, I will be explaining the detection system with the step-by-step process. This example will use the phishing technique of a fake login alert to show the process behind the detection system. Make sure to adapt this structure based on the phishing technique that your threat model commonly uses.

- The first step of this phishing detection system is to calm down
- This can be done by taking a few deep breaths
- The second step is to identify what the fake login alert is about
- For example, the email could be from Spotify or from your bank
- If the email is from a service, you don't use then it is suspicious by default
- The third step is verification
- This is where you would check the email for the signs of phishing
- This step can be directly supported by the usage of security training
- Sometimes an attacker can use AI-generated phishing emails to trick you
- If the grammar seems too perfect, you may check against 1 or 2 AI detectors for AI usage
- Do not only rely on the step above for detecting fake login alerts
- The fourth step is cross-referencing
- This is where you would cross-reference against real login alerts from the past
- These real login alerts should be stored securely but remain accessible for quick and effective usage.
- They should not be stored in your email as an attacker can compromise that more easily.
- There is one rule that should be followed even if the email has bypassed all verification steps
- This rule is to never click on the link and verify through the actual website by manually typing in the domain
- The final step is to document the attempt
- This can use the structure What (What was the phishing technique) → Why (What was the goal behind it?) → How (How did you detect it?) → Potential improvements (What could be improved for next time?)

There is also an extra step below that organisations may set up for further protection and detection against phishing.

- A company can setup an ML model which uses behavioural and signature-based detection
- The company can use their own logs and login alerts for the training data of the model
- They can also train the ML model to recognise the signs of phishing
- This ML model should block for high probability cases but flag to the user for low probability cases. It is important to note that they may be false positives.

Technical controls against phishing

While the main phishing detection system is strong and effective for preventing successful phishing, it relies heavily on behavioural and human detection with no safety net in the case of human error. These technical controls can provide a safety net in the case of human error as humans aren't perfect. However, these technical controls cannot fully guarantee that it will completely prevent unauthorized access.

- There are 4 protections that can be implemented against phishing
- The first protection is strong unique 12-16 characters passwords for each account
- These passwords should be stored securely in a password manager
- This protects against phishing because it prevents an attacker from using compromised credentials to breach multiple accounts
- The second protection is MFA which stands for multi factor authentication
- MFA should be through authentication apps or hardware keys
- Try avoiding SMS or Email-based MFA when possible
- This protects against phishing because it prevents unauthorized access to your account even if an attacker has compromised your password.
- The third protection is OPSEC which stands for operational security
- You should limit the information that is publicly available on social media and other sources
- This is because social media is the most common source of information gathering which allows an attacker to perform spear-phishing attacks
- This protects against phishing because an attacker can't use spear-phishing or most other types of phishing if they don't have information on you
- The fourth protection is RBAC which stands for Role-based access control
- This is where you would limit permissions of others in your systems
- For example, you may not use the same email for recovery for all your accounts
- This could mean using a separate and isolated account as recovery for your bank account.

